



❖ 1.1.4 AUTHENTICATION

Authentication is the method to validate a user or device/application to be able to gain access. Authentication is one of the first steps in information system protection, as it prevents unauthorized users from accessing sensitive resources. Modern systems use distinct **techniques** of authentication in order to provide the needed security **level** and drastically reduce cyberattacks.

► **Example:** Entering a username and password is an example of authentication using something you know. Receiving a One-Time Password (OTP) on your phone is authentication using something you have. Using a fingerprint or face scan is authentication using something you are, known as biometric authentication. Many online services combine two methods, called Multi-Factor Authentication (MFA), to provide stronger security.



Something You Know

The **knowledge** factor — this authentication type uses something the user knows like a password, PIN or security question. It is the most widely used authentication **method** due to its simplicity and low cost.

■ Something You Have

This authentication **factor** relies on what the user physically possesses. This can be a smart **card**, security token, mobile phone or USB security key, for example. Most online **services** send an OTP or verification code to a user registered with a phone number or email. If a **password** is stolen, the second authentication factor still protects access to the account from an attacker.

■ Something You Are

This type of authentication **factor** utilizes biometric data which is based on the unique physical **attributes** of a person. Some common biometric **systems** are fingerprint recognition, facial recognition, face scan or voice **prints**. The biometric **authentication** technique is considered one of the strongest security measures since every person has different biological features.

■ Multi-Factor Authentication (MFA)

Multi-Factor Authentication (MFA) uses two or more **methods** of verification to confirm a user is authentic. A recognized **example** of this is entering a password and then an OTP sent to your mobile. This greatly ensures that your **account** is not accessed illegally and



credentials are safe. MFA is a much more secure **means** to access your data. Banks and social media **platforms** now require MFA to access their services along with traditional processes using passwords or keys.

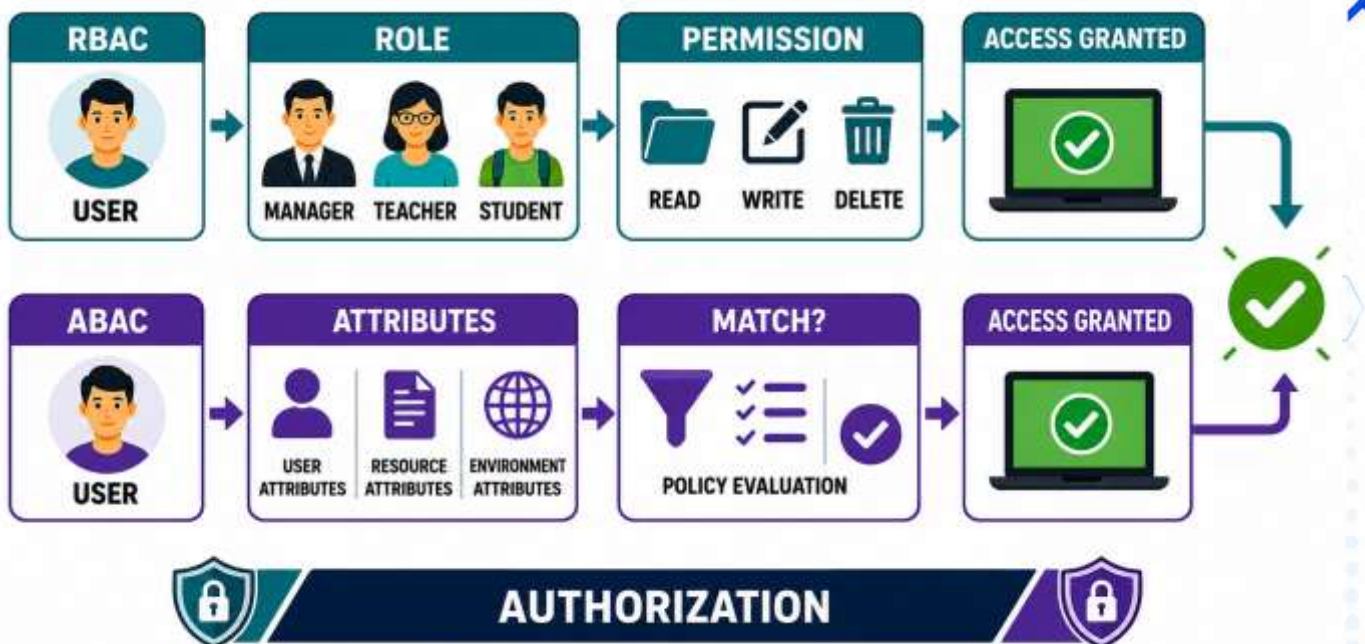
■ Importance of Authentication

Authentication validates only **legitimate** users to access systems and information. Attackers could exploit weak **authentication** for arbitrary command execution and data extraction, leading to unauthorized access to sensitive **information**. Moreover, strong authentication **methods** protect organizations from identity theft as well as data breaches and cybercrime.

❖ 1.1.5 AUTHORIZATION (RBAC AND ABAC)

Authorization refers to what an authenticated user can access from the system. This takes place only after a user has been authenticated. Authorization protects **sensitive** information by granting users only the access that they need to perform their jobs. This may definitely be the whole question of "What can you do?"

► **Example:** In Role-Based Access Control (RBAC), permissions are assigned according to a person's job role. For example, a teacher can enter grades, but students can only view them. In Attribute-Based Access Control (ABAC), access decisions depend on attributes such as the user's department, location, device, or time of access. For example, an employee may only access company data while connected to the office network during working hours.



■ Attribute-Based Access Control (ABAC)

ABAC (Attribute-Based Access Control) grants **access** on the basis of predefined security rules with specific **attributes**. These can be attributes like department, location, device



type, security clearance or time of access. ABAC is more **versatile** than RBAC in that it can derive decisions from many possible conditions. By employing such an **approach**, it is widely deployed in large organizations or cloud computing environments.

Example: An employee requests access to confidential company files. The system checks the employee's department, location, device, and access time. All required attributes match the security policy. The system grants access to the files. Another user fails one of the required attribute checks. The system denies access automatically.

Example: How Attribute-Based Access Control (ABAC) Works



Permissions and Access Rights

Permissions allow users to carry out operations within a given system. Read, write, modify, delete and **execute** are some of the common permissions. By ensuring that permissions are correctly handled and **authorized**, you save yourself from unauthorized access, data leaks and inadvertent modifications of critical information. Organizations frequently review **access** rights to make sure users only have the permissions they need.

Authorization and the Principle of Least Privilege

Authorization is inextricably linked with the Principle of Least **Privilege** (PoLP). This **principle** states that users should have only the minimum permissions required to do their job. By restricting **access**, the risk of insider threats, malware infections and accidental data modifications is minimized. The effect of applying least **privilege** is overall better security for an organization.

❖ 1.1.6 ROLES IN CYBERSECURITY

Cybersecurity is a vast and booming field that offers multiple job roles. **Specialists** work together to safeguard your information systems, networks and digital property against cyber threats. In today's digital world, every individual has a responsibility to use technology safely and responsibly. Practicing good cyber hygiene helps protect personal information, devices, and online accounts from common cyber threats.

► **Example:** A Security Analyst monitors networks and investigates suspicious activities. An Ethical Hacker or Penetration Tester legally attempts to break into systems to discover

CHAPTER 1



INTRODUCTION TO CYBERSECURITY

vulnerabilities before criminals do. A Security Engineer designs and implements security technologies such as firewalls and intrusion detection systems. A Digital Forensics Investigator collects and analyzes digital evidence after a cyberattack, while an Incident Responder works to contain and recover from security breaches.



■ Security Analyst

The Security **Analyst** is in charge of monitoring computer systems and networks for suspicious activity. They employ Security Information and Event **Management** (SIEM) tools to sift through security logs in order to detect threats. Security analysts look into **alerts**, respond to incidents and recommend security improvements. They prevent **cyberattacks** before they escalate.

■ Security Engineer

In an organization, the Security **Engineer** designs, implements and maintains security technologies in order to keep an organization protected. They set up **firewalls**, IDS, IPS and encryption systems. Security engineers also design **tests** to confirm the security features of software and build strategies to improve the defenses put in place by the organization. Their **work** provides the technical bedrock of cybersecurity.



■ Ethical Hacker (Penetration Tester)

An Ethical **Hacker**, or Penetration Tester, attempts to gain access to systems in order to identify vulnerabilities and weaknesses (legally). Like **attackers**, they apply the same approaches but with permission from the organization. Once the **assessment** has been completed, they give suggestions to strengthen security. Ethical **hacking** provides organizations with a solution to those problems in advance of bad actors who may attempt to exploit them.

■ Incident Responder

The Incident **Responder** administers the security incident response, starting with a malware infection, data breach or ransomware attack. They are responsible for **recognizing** the attack, limiting damage and getting things back to normal. They could also advise how to avoid similar **incidents** occurring in the future and write reports. **Digital Forensics Investigator**

Digital Forensics **Investigator**: This is the person who collects, preserves and analyzes digital evidence in a cybercrime or security incident. They go through **computers**, mobile devices and network logs to see how the attack happened. The **data** they find can be used in investigations and court cases. Digital **forensics** is critical to identifying the attacking party and understanding cyber incidents.

■ Security Manager

A Security **Manager** develops security policies and also runs the organization's cybersecurity program. They oversee risk assessments, perform risk assessments and ensure **compliance** with laws and regulations. Security managers also coordinate **responses** to incidents and assign personnel for the security program. With their **leadership**, organizations develop a strong culture of security.

■ Chief Information Security Officer (CISO)

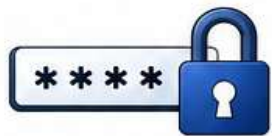
Chief Information Security Officer (**CISO**): The CISO is a senior executive position ultimately responsible for the information security strategy of an organization. CISOs plan long-term **security** objectives, manage cybersecurity budgets and communicate **risk** to senior management.

SESSION REVIEW



1.1.4 AUTHENTICATION

Something You Know



- Uses something the user knows like a password or PIN.

Something You Have



- Relies on what the user physically possesses.

Something You Are



- Utilizes biometric data based on unique physical attributes.

Multi-Factor Authentication (MFA)



- Uses two or more methods of verification.

Importance of Authentication



- Validates only legitimate users to access systems and information.

1.1.5 AUTHORIZATION (RBAC AND ABAC)

Attribute-Based Access Control (ABAC)



- Grants access on predefined security rules with specific attributes.

Permissions and Access Rights



- Allow users to carry out operations within a system.

Authorization and the Principle of Least Privilege



- Users have only the minimum permissions required.

Importance of Authorization



- Protects users from reaching unrelated information.

1.1.6 JOB ROLES IN CYBERSECURITY

Security Analyst



- Monitors computer systems and networks for suspicious activity.

Security Engineer



- Designs, implements, and maintains security technologies.

Ethical Hacker (Penetration Tester)



- Legally identifies vulnerabilities and weaknesses in systems.

Incident Responder



- Recognizes attacks, limits damage, and restores normal operations.

Digital Forensics Investigator



- Collects, preserves, and analyzes digital evidence.

Security Manager



- Develops security policies and manages cybersecurity programs.

Chief Information Security Officer (CISO)



- Responsible for the organization's information security strategy.

SUMMARY

CHAPTER 1: INTRODUCTION TO CYBERSECURITY



This chapter introduced the Fundamentals of Cybersecurity and the importance of protecting computers, networks, applications, and digital information. It explained key principles, including Risk Management, Defense in Depth, Least Privilege, Security Awareness, and Regular Updates. You learned how the CIA Triad—Confidentiality, Integrity, and Availability—forms the foundation of information security. The chapter also covered Authentication, Multi-Factor Authentication (MFA), Authorization, RBAC, and ABAC for secure access control. Finally, it introduced the roles and responsibilities of various Cybersecurity Professionals.

1.1.1 CYBERSECURITY BASICS



- Protecting Digital Information
- Protecting Systems and Networks
- Preventing and Responding to Cyberattacks
- Why do we need Cybersecurity in daily life?

1.1.2 CIA TRIAD



- Confidentiality
- Integrity
- Availability

1.1.3 KEY PRINCIPLES OF CYBERSECURITY



- Risk Management
- Defense in Depth
- Principle of Least Privilege
- Security Awareness
- Regular Updates and Patching

1.1.4 AUTHENTICATION



- Something You Know
- Something You Have
- Something You Are
- Multi-Factor Authentication (MFA)
- Importance of Authentication

1.1.5 AUTHORIZATION (RBAC AND ABAC)



- Attribute-Based Access Control (ABAC)
- Permissions and Access Rights
- Authorization and the Principle of Least Privilege
- Importance of Authorization

1.1.6 JOB ROLES IN CYBERSECURITY



- Security Analyst
- Security Engineer
- Ethical Hacker (Penetration Tester)
- Incident Responder
- Digital Forensics Investigator
- Security Manager
- Chief Information Security Officer (CISO)
- Importance of Cybersecurity Careers

CYBERPEDIA

CHAPTER 1: INTRODUCTION TO CYBERSECURITY



1



Cybersecurity –

The protection of computers, networks, software and information from harm, theft or unauthorized access.

6



Authentication –

A method to validate user or device/application to be able to get access.

2



Vulnerability –

A weakness or a defect in hardware, software programs, network configurations or even human behavior that can be exploited by an adversary.

7



Multi-Factor Authentication (MFA) –

Multi-Factor Authentication (MFA) – Uses two or more methods of verification to confirm a user is authentic.

3



CIA Triad –

One of the fundamental models in cybersecurity (Confidentiality, Integrity and Availability).

8



Principle of Least Privilege (PoLP) –

Users must only be given permissions needed to do their jobs.

4



Social Engineering –

A type of threat that does not directly attack a computer or software system but manipulates people.

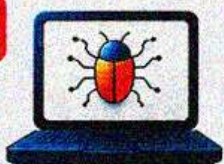
9



Authorization –

Refers to what an authenticated user can access from the system.

5



Malware –

Any program or file that is harmful to a computer user (malicious software).

10



Risk Management –

The process of identifying, analyzing and minimizing security threats which may affect an organization.



EXERCISE

PART-A: MULTIPLE CHOICE QUESTIONS



1 What is the primary function of cybersecurity according to the text?



- A) To increase internet speed
- B) To maintain confidentiality, integrity, and availability of information
- C) To design new software applications
- D) To manage employee salaries

2 Which of the following is an example of protecting digital information?



- A) Installing a firewall
- B) Using encryption, access control, and backup systems
- C) Monitoring network traffic
- D) Responding to phishing emails

3 What is the process of identifying, analyzing, and minimizing security threats called?



- A) Vulnerability assessment
- B) Risk management
- C) Defense in Depth
- D) Security awareness

4 Which security approach uses multiple layers of defense so that if one fails, others continue to protect?



- A) Principle of Least Privilege
- B) Risk Management
- C) Defense in Depth
- D) Authentication

5 According to the Principle of Least Privilege (PoLP), users should:



- A) Have full access to all systems
- B) Only be given permissions needed to do their jobs
- C) Change passwords daily
- D) Use biometric authentication always

6 Which component of the CIA Triad ensures that information is accurate and unaltered unless modified by an authorized person?



- A) Confidentiality
- B) Integrity
- C) Availability
- D) Authentication

7 A hospital keeps backup servers and emergency power systems to ensure patient records are accessible even during failures. This protects which CIA principle?



- A) Confidentiality
- B) Integrity
- C) Availability
- D) Non-repudiation

8 Entering a password and then receiving a One-Time Password (OTP) on your phone is an example of:



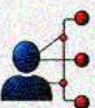
- A) Single-factor authentication
- B) Biometric authentication
- C) Multi-Factor Authentication (MFA)
- D) Authorization

9 Which authentication factor uses unique physical attributes like fingerprints or face scans?



- A) Something you know
- B) Something you have
- C) Something you are
- D) Something you do

10 In Attribute-Based Access Control (ABAC), access decisions are based on:



- A) Only the user's job title
- B) Predefined attributes like department, location, or time
- C) The user's password strength
- D) The user's age

11 What does authorization determine after a user is authenticated?



- A) Who the user is
- B) What the user can access
- C) How the user logged in
- D) Where the user is located

12 Which job role is responsible for legally attempting to break into systems to find vulnerabilities?



- A) Security Analyst
- B) Security Engineer
- C) Ethical Hacker (Penetration Tester)
- D) Incident Responder

EXERCISE

PART-B: CYBERSECURITY ANALYSIS

INSTRUCTIONS:

As a cybersecurity professional, analyze each scenario and find the most appropriate solutions. Use the guided steps to organize your analysis.



1. SHARED SCHOOL ACCOUNT

A school allows several teachers to use the same login account to access the student grading system. One day, some student grades are changed without permission. The school cannot identify who made the changes.

GUIDED STEPS



Identify the cybersecurity problem.



Determine which cybersecurity principles are not being followed.



Explain how authentication and authorization should be improved.



Recommend security measures to prevent similar incidents.



2. IGNORED SOFTWARE UPDATES

A company delays software updates for several months because employees do not want interruptions during work. Later, attackers exploit a known software vulnerability and gain access to company files.

GUIDED STEPS



Identify the main cause of the security incident.



Determine which cybersecurity principle was ignored.



Explain how attackers exploited the vulnerability.



Recommend practices to reduce similar risks.

PART-C: SHORT ANSWER TYPE QUESTIONS

1



Explain the CIA Triad and provide one example of how each principle (Confidentiality, Integrity, and Availability) can be protected in an organization.

2



What is the difference between Authentication and Authorization? Provide one example of each.

3



Describe the Principle of Least Privilege (PoLP) and explain why it is important for organizational security.



CASE STUDY

CyberAttack At: SMART FUTURE SCHOOL

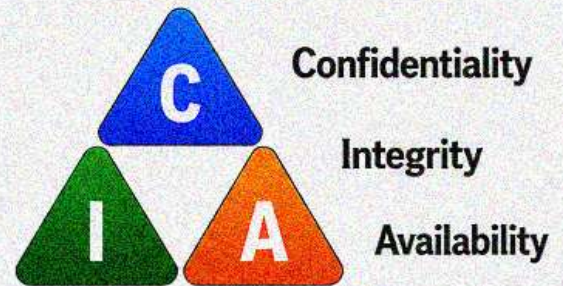


Smart Future School uses computers to manage attendance, grades, student records. One day, teachers discovered that grades had been changed without permission, the network was very slow, and important files were inaccessible. The IT team found several security weaknesses. Teachers shared one login account, used weak passwords, and did not enable Multi-Factor Authentication (MFA). Everyone had permission to view, edit, and delete student records. An employee connected an unknown USB drive, software updates and antivirus were outdated, and important files were not backed up regularly. The cybersecurity team isolated affected computers, monitored the network, restored available backups, and investigated the attack. The school then decided to improve authentication, authorization, regular patching, security awareness, backups, and other cybersecurity measures.



I: ANALYZE THE INCIDENT

1. Identify **five** cybersecurity weaknesses.
2. Which **CIA Triad** principles were affected? Explain.



II: RECOMMEND SOLUTIONS

1. Recommend **six** security improvements.
2. Explain how **Risk Management**, **Defense in Depth**, and **PoLP** could prevent similar incidents.
3. Which **authentication methods** would you recommend for teachers? Why?



III: CYBERSECURITY JOB ROLES

Task	Job Role
Monitor network and detect suspicious activities	_____
Test systems for weaknesses before attackers exploit them	_____
Respond to attack and restore systems	_____
Collect and analyze digital evidence	_____



IV: YOUR ROLE (CISO)

Write a **150–200** word report covering:

- Major problems
- Risks faced
- Recommended improvements



END OF CHAPTER